

STATIC MOBILE MALWARE ANALYSIS REPORT

Sample: Android.Spy.49 — iBanking Banking Trojan

By

Iwuji Chikaodi Edith

Executive Summary

This report presents the findings of a static analysis performed on three Android malware samples extracted from the archive `Android.Spy.49_iBanking_Feb2014.zip`. The samples are variants of the iBanking banking trojan, a well-documented family of Android malware first identified circa 2013–2014. The analysis was conducted using the Mobile Security Framework (MobSF) on Kali Linux, supplemented by external threat intelligence sources including VirusTotal, MetaDefender, Hybrid Analysis, and Triage (Recorded Future).

All three samples — `bot.apk`, `ING.apk`, and `ING_.apk` received a MobSF security score of 41/100, indicating high risk. The samples collectively request 15 permissions, including 6 classified as dangerous, and exhibit behaviour consistent with a banking trojan and spyware, including SMS interception, contact exfiltration, audio recording, device fingerprinting, and communication with a remote Command and Control (C2) server hosted in Portugal.

VirusTotal flagged `bot.apk` as malicious by 41 out of 67 antivirus engines, while `ING.apk` and `ING_.apk` were each flagged by 40–41 out of 68 engines. MetaDefender's sandbox assigned a 100/100 threat score to `bot.apk`. The malware disguises itself as legitimate banking or security applications (ING Bank, Commonwealth Bank, Postbank, and others) to deceive victims.

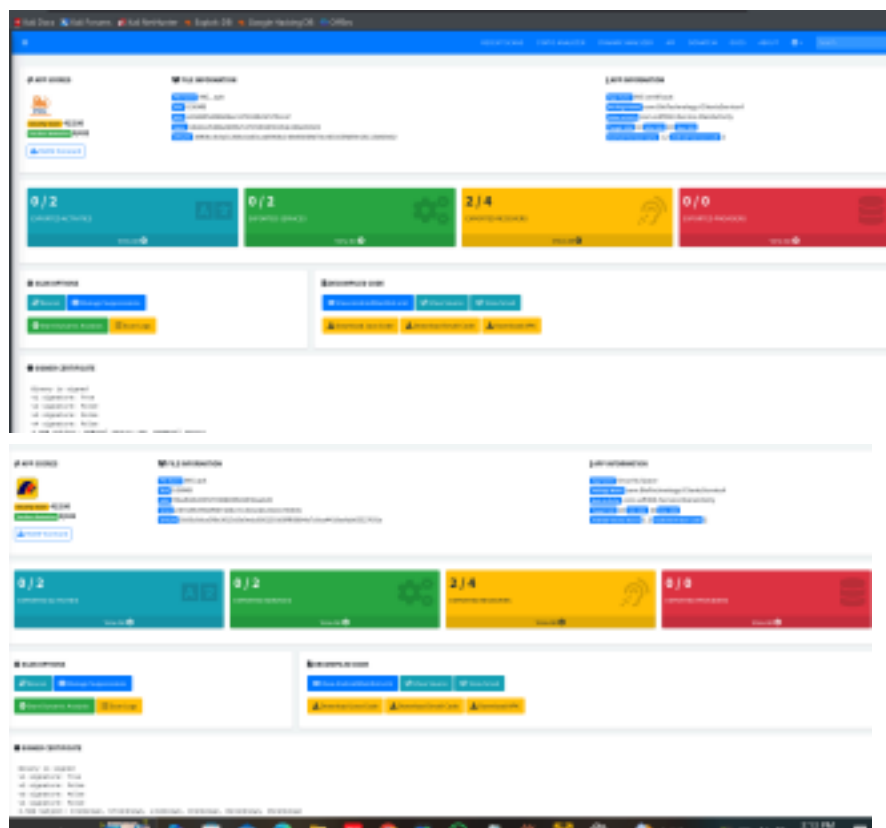
This report covers the static analysis methodology, detailed findings per sample, indicators of compromise (IoCs), risk assessment, and recommendations.

2. Sample Information

2.1 Overview of Samples

The malware archive contained three APK files, all belonging to the iBanking malware family. The table below summarises the file information for each sample.

Field	bot.apk	ING.apk	ING_.apk
File Name	bot.apk	ING.apk	ING_.apk
App Name	Android	Security Space	ING certificaat
File Size	0.56 MB	0.56 MB	0.56 MB (591 KB)
MD5	f0a1475583278466b673 ac902b664e42	f06af629d33f17938849f82293 0ae428	e1b86054468d6ac1274188c0 c579ccaf
SHA-1	aa9436771a1c98639d1deb7330c6aac524bb2a a4	23f7a99cf90df9673d6c7ec31b ed1e611b73003c	b6d2ec548be8836c5171fd024 3813de1b6e01822
SHA-256	2b29d93e58ab328a0c9418001d7748dc4c50b514c8074f4c00556b890d f31644	0106c6dce5f8e3615d3e9edc856230109ff06884a7c6ea4418 eefab055270f1e	38f6fccfc8a31306c0a03cad6908c148e8506fd70ce03165fd8 9e18113b68e02
Package Name	com.BioTechnology.iC lie ntsService4	com.BioTechnology.iClients Se rvice4	com.BioTechnology.iClients Se rvice4
MobSF Score	41/100	41/100	41/100
Bot ID	500	500	153
C2 Domain	tmn.pt	tmn.pt	tmn.pt
C2 Path	/android/	/android/	/iBanking/



2.2 Malware Family Background

iBanking (also known as Android.Spy.49, Binka, Android:Nitmo) is a sophisticated Android banking trojan and mobile spyware that emerged around 2013. It is designed to steal banking credentials by intercepting SMS-based One-Time Passwords (OTPs) used in two-factor authentication (2FA) for online banking. The malware disguises itself as legitimate applications such as bank security tools or antivirus software to trick users into installing it.

The iBanking malware family has been linked to cybercriminal groups targeting customers of major European banks including ING Bank (Netherlands), Postbank (Germany), and Commonwealth Bank of Australia. It has been documented and tracked by major security vendors since 2013 and remains in public malware repositories for research purposes.

3. Static Analysis Findings

3.1 Certificate Analysis

All three samples are signed using only the v1 signature scheme (JAR signing). This makes them vulnerable to the Janus vulnerability (CVE-2017-13156), which affects Android 5.0 to 8.0 and allows an attacker to modify an APK without invalidating its signature.

bot.apk and ING.apk share an identical certificate with all fields set to 'Unknown', indicating the certificate was self-signed and provides no verified identity. ING_.apk has a different certificate signed under the organisation 'Movel Seguro LDA' with CN=Movel Seguro, suggesting it was created by a different actor or at a different stage of development.

Certificate Field	bot.apk	ING.apk	ING_.apk
Signature Scheme	v1 only	v1 only	v1 only
Subject/Issuer	All Unknown	All Unknown	Movel Seguro LDA
Valid From	2013-12-02	2013-12-02	2013-07-12
Valid To	2041-04-19	2041-04-19	3012-11-12
Janus Vulnerable	Yes	Yes	Yes



3.2 Manifest Analysis

The AndroidManifest.xml of all three samples revealed several high-risk and warning-level issues. These are consistent across all variants:

#	Severity	Issue
1	HIGH	App targets Android 2.3.3–2.3.7 (minSdk=10), which has multiple unpatched vulnerabilities and no security updates from Google.
2	WARNING	android:allowBackup=true — allows backup of application data via ADB by anyone with USB debugging access.
3	WARNING	Broadcast Receiver (com.soft360.Receiver.MyPhoneReceiver) is unprotected and exported, making it accessible to any other app on the device.
4	WARNING	Broadcast Receiver (com.soft360.web.MyAdmin) is exported with BIND_DEVICE_ADMIN permission — a device administrator receiver that can wipe the device.

3.3 Permission Analysis

All three APKs request 15 permissions, of which 6 are classified as dangerous by Android. These permissions, combined, provide the malware with comprehensive surveillance and control capabilities.

Permission	Status	Malicious Use
READ_SMS / RECEIVE_SMS / SEND_SMS	DANGEROUS	Intercepts OTP codes for banking 2FA bypass; sends SMS to C2 or premium numbers.
READ_PHONE_STATE	DANGEROUS	Extracts IMEI, phone number, SIM serial (ICCID), and call state for device fingerprinting.
READ_CONTACTS	DANGEROUS	Steals contact list for exfiltration to C2 server.
CALL_PHONE	DANGEROUS	Makes phone calls without user intervention, potentially to premium-rate numbers.
RECORD_AUDIO	DANGEROUS	Records audio from microphone — enables eavesdropping on conversations.
WRITE_EXTERNAL_STORAGE	DANGEROUS	Writes captured data to SD card for later retrieval.
RECEIVE_BOOT_COMPLETED	NORMAL	Ensures persistence — malware starts automatically on device boot.
INTERNET	NORMAL	Enables communication with C2 server.

MobSF identified 11 out of 25 top malware permissions and 4 out of 44 other common malware permissions as present in all three samples. This represents a very high overlap with known malware permission profiles.

PERMISSION	STATUS	INFO	DESCRIPTION	CODE MAPPING
android.permission.ACCESS_NETWORK_STATE	granted	view network status	Allows an application to view the status of all networks.	View Code
android.permission.ACCESS_WIFI_STATE	granted	view Wi-Fi status	Allows an application to view the information about the status of Wi-Fi.	
android.permission.CALL_PHONE	denied	directly call phone numbers	Allows the application to call phone numbers without your intervention. Malicious applications may cause unexpected calls on your phone bill. Note that this does not allow the application to call emergency numbers.	
android.permission.CHANGE_NETWORK_STATE	granted	change network connectivity	Allows applications to change network connectivity state.	
android.permission.CHANGE_WIFI_STATE	granted	change Wi-Fi status	Allows an application to connect to and disconnect from Wi-Fi access points and to make changes to configured Wi-Fi networks.	
android.permission.INTERNET	granted	full Internet access	Allows an application to create network sockets.	View Code
android.permission.READ_CONTACTS	denied	read contact data	Allows an application to read all the contact (address) data stored on your phone. Malicious applications can use this to send your data to other people.	View Code
android.permission.READ_PHONE_STATE	denied	read phone state and identity	Allows the application to access the phone features of the device. An application with this permission can determine the phone number and serial number of this phone, whether a call is active, the number that call is connected to and so on.	View Code
android.permission.READ_SMS	denied	read SMS or MMS	Allows application to read SMS messages stored on your phone or SIM card. Malicious applications may read your confidential messages.	
android.permission.RECEIVE_BOOT_COMPLETED	granted	automatically start at boot	Allows an application to start itself as soon as the system has finished booting. This can make it take longer to start the phone and allow the application to view down the powerd phone by always running.	View Code

Showing 1 to 11 of 11 entries

Previous 1 2 Next

DEAPPLICATION PERMISSIONS

PERMISSION	STATUS	INFO	DESCRIPTION	CODE MAPPING
android.permission.ACCESS_NETWORK_STATE	granted	view network status	Allows an application to view the status of all networks.	View Code
android.permission.ACCESS_WIFI_STATE	granted	view Wi-Fi status	Allows an application to view the information about the status of Wi-Fi.	
android.permission.CALL_PHONE	denied	directly call phone numbers	Allows the application to call phone numbers without your intervention. Malicious applications may cause unexpected calls on your phone bill. Note that this does not allow the application to call emergency numbers.	
android.permission.CHANGE_NETWORK_STATE	granted	change network connectivity	Allows applications to change network connectivity state.	
android.permission.CHANGE_WIFI_STATE	granted	change Wi-Fi status	Allows an application to connect to and disconnect from Wi-Fi access points and to make changes to configured Wi-Fi networks.	
android.permission.INTERNET	granted	full Internet access	Allows an application to create network sockets.	View Code
android.permission.READ_CONTACTS	denied	read contact data	Allows an application to read all the contact (address) data stored on your phone. Malicious applications can use this to send your data to other people.	View Code
android.permission.READ_PHONE_STATE	denied	read phone state and identity	Allows the application to access the phone features of the device. An application with this permission can determine the phone number and serial number of this phone, whether a call is active, the number that call is connected to and so on.	View Code
android.permission.READ_SMS	denied	read SMS or MMS	Allows application to read SMS messages stored on your phone or SIM card. Malicious applications may read your confidential messages.	
android.permission.RECEIVE_BOOT_COMPLETED	granted	automatically start at boot	Allows an application to start itself as soon as the system has finished booting. This can make it take longer to start the phone and allow the application to view down the powerd phone by always running.	View Code

Showing 1 to 11 of 11 entries

Previous 1 2 Next

3.4 Code Analysis

MobSF's code analysis flagged four issues in each sample. The most significant are:

#	Severity	Standard	Description
1	HIGH	CWE-919 / OWASP M1	Debug mode enabled in production build (BuildConfig.java). Exposes internal application state.
2	WARNING	CWE-276 / OWASP M2	App reads and writes to external storage (AudioRecorder.java) — captured audio files are accessible to other apps.
3	WARNING	CWE-89 / OWASP M7	Raw SQL queries executed without parameterisation (dbActions.java), risking SQL injection against the local

			database.
--	--	--	-----------

4	INFO	CWE-532 / MASVS	Application logs sensitive information that should never appear in logs.
---	------	-----------------	--

3.5 Behaviour Analysis

MobSF's behaviour analysis revealed 27 distinct malicious behavioural patterns across all samples. Key behaviours include:

- **IMEI and Device Fingerprinting:** Queries IMEI number, phone number, ICCID (SIM serial), and subscriber ID via dbActions.java and webServiceRobot.java.
- **SMS Interception:** Reads SMS message content, sender phone numbers, and SMS metadata via SmsReciever.java and dbActions.java. Intercepted SMS messages are stored in a local SQLite database (iBankDB_23.db) and transmitted to the C2 server
- **Audio Recording:** Records audio using an absolute file path (AudioRecorder.java), storing recordings on external storage for exfiltration.
- **Contact List Exfiltration:** Queries and transmits the full device contact list to the C2 server.
- **Call Monitoring:** Monitors incoming and outgoing calls (MyPhoneReceiver.java).
- **Persistence via Boot Receiver:** The AutoStart receiver triggers on BOOT_COMPLETED, ensuring the malware restarts every time the device is rebooted
- **Device Administration Abuse:** Requests device administrator privileges via MyAdmin (BIND_DEVICE_ADMIN), enabling screen lock, password reset, and remote wipe capabilities
- **C2 Communication:** Communicates with the C2 server via multiple PHP endpoints for data exfiltration and command retrieval.

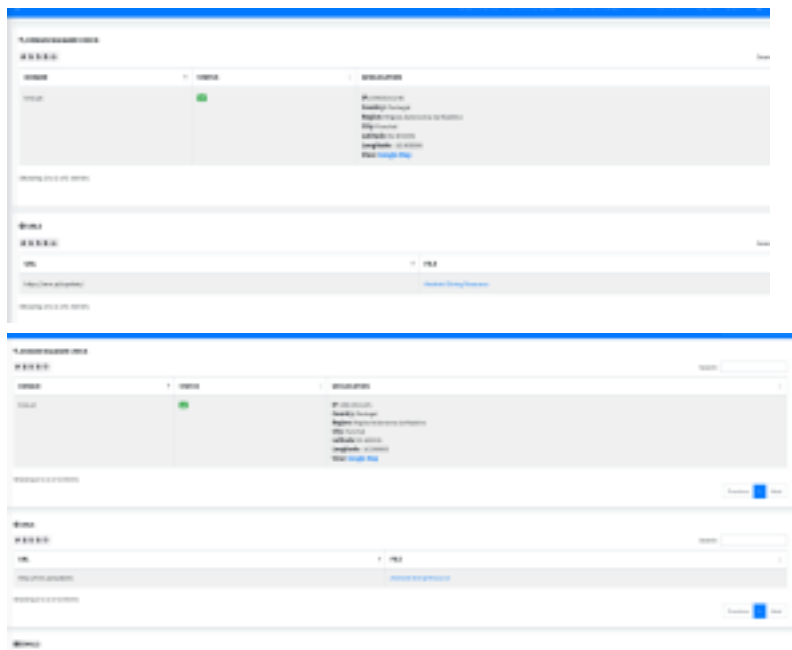
ID	DESCRIPTION	CATEGORY	DETAILS
00007	Use absolute path to traverse to the target media file path	FILE	android.os.Environment.getExternalStorageDirectory() + "/data/data/com.example.mobsf/"
00008	Read the sms messages in device	FILE	android.provider.Telephony.Sms.getDefaultUri()
00009	Query the file path to the absolute path of the file	FILE	android.os.Environment.getExternalStorageDirectory() + "/data/data/com.example.mobsf/"
00010	Query the IMEI number	DEVICE	android.telephony.TelephonyManager.getImei()
00011	Query the phone number	DEVICE	android.telephony.TelephonyManager.getLine1Number()
00012	Query the ICCID number	DEVICE	android.telephony.TelephonyManager.getIccid()
00013	Query the phone number from SIM card	DEVICE	android.telephony.TelephonyManager.getSimSerialNumber()
00014	Query the ICCID number and the phone number	DEVICE	android.telephony.TelephonyManager.getSimSerialNumber() + " " + android.telephony.TelephonyManager.getLine1Number()
00015	Request device administrator privileges (e.g., screen lock, password reset, etc.)	ADMIN	android.app.admin.DevicePolicyManager.setDevicePolicyManager()
00016	Query the device location	LOCATION	android.location.LocationManager.getLastKnownLocation()

3.6 Network Indicators and C2 Infrastructure

All three samples communicate with the same C2 domain: tmn.pt, hosted in Funchal, Madeira, Portugal (IP: 194.65.61.45). The domain was verified as active at the time of original infection.

Indicator	Value
C2 Domain	tmn.pt
C2 IP Address	194.65.61.45
Country	Portugal (Regiao Autonoma da Madeira)
Update URL	http://tmn.pt/update/
SMS Endpoint	/android/sms/saveSMS.php /iBanking/sms/saveSMS.php
Sync Endpoint	/android/sms/sync.php /iBanking/sms/sync.php
Ping Endpoint	/android/sms/ping.php /iBanking/sms/ping.php
Data Endpoint	/android/sms/index.php /iBanking/sms/index.php
File Upload	/android/sendFile.php /iBanking/sendFile.php

The C2 infrastructure uses a standard HTTP (unencrypted) protocol, meaning all data exfiltrated by the malware including SMS messages containing OTP codes is transmitted in plaintext.



3.7 Hardcoded Strings and Social Engineering

Analysis of hardcoded strings in all three APKs revealed a sophisticated multi-language, multi-bank impersonation scheme. The malware contains templates targeting customers in multiple countries:

- ING Bank N.V. (Netherlands) — Dutch language template requesting activation codes
- Postbank (Germany) — German language template
- Commonwealth Bank of Australia — English language template
- TMN (Portugal) — Portuguese language social engineering message
- Polish banking template (unnamed bank)

The social engineering message hardcoded in all variants (Portuguese) warns the user that their Android device has a vulnerability and instructs them to install a "security certificate" from <http://tmn.pt/update/>. This classic social engineering tactic exploits user trust in their mobile carrier (TMN is a Portuguese telecom operator).

Additional hardcoded values of note include:

- bot_id: 500 (bot.apk and ING.apk) / 153 (ING_.apk) — unique bot identifiers for C2 tracking
- def_tel_number: +700000000003 (bot.apk, ING.apk) / +447781481797 (ING_.apk) — ING_.apk targets UK (+44) numbers
- A hardcoded bot authentication key: 637f-bsnj-70ak-bs2e

4. Comparative Analysis of Variants

All three samples share the same package name (com.BioTechnology.iClientsService4), the same C2 domain (tmn.pt), and the same set of permissions and behavioural patterns. This confirms they are variants of the same malware strain, likely developed and distributed at different times or targeting different victim groups.

Distinguishing Factor	bot.apk	ING.apk	ING_.apk
Disguise Name	Android (generic)	Security Space	ING certificaat
Certificate Identity	Unknown/Anonymous	Unknown/Anonymous	Movel Seguro LDA
Compiler	dexlib 2.x	dexlib 2.x	dx + dexmerge
Default C2 Number	+700000000003	+700000000003	+447781481797 (UK)
Target Region (Implied)	Generic/Portugal	Generic/Portugal	United Kingdom

VirusTotal Detection	41/67	41/68	40/68
----------------------	-------	-------	-------

ING_.apk is notable for being the most targeted variant, it directly impersonates ING Bank by name, uses a different certificate organisation (Movel Seguro LDA, Portuguese for 'Mobile Secure Ltd'), and contains a UK phone number, suggesting it was distributed to target ING Bank customers in the United Kingdom. The change in C2 path from /android/ to /iBanking/ in ING_.apk also indicates a potential infrastructure update or campaign change.

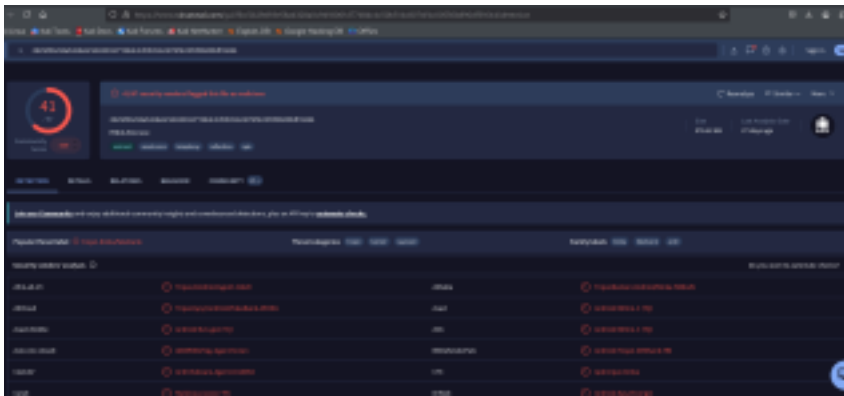
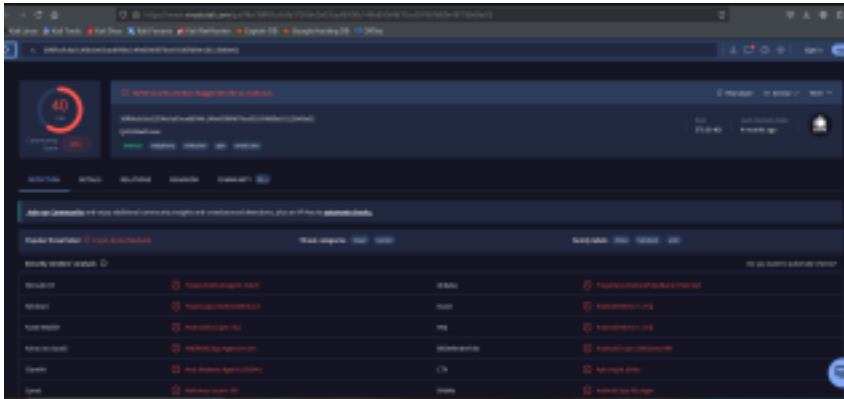
5. Threat Intelligence Correlation

The samples were cross-referenced against multiple external threat intelligence platforms to validate and enrich the findings:

Platform	bot.apk	ING.apk	ING_.apk
VirusTotal	41/67 detected	41/68 detected	40/68 detected
MetaDefender	7/23 + Sandbox 100/100	14/36 + Malicious	14/36 + Malicious
Hybrid Analysis	Threat Score 100/100 (2017)	N/A	N/A
Triage	Score 6/10 Reported	Score 6/10 Reported	Score 6/10 Reported

Common threat labels assigned by antivirus vendors include: Trojan-Banker.AndroidOS.Binka (Kaspersky), Android.Spy.49.origin (DrWeb), Trojan:iBanking (Symantec), Android/Spy.Agent.AF (ESET), and TrojanSpy:Android/FakeBank (Microsoft). The consensus across vendors confirms classification as a banking trojan with spyware capabilities.

Hybrid Analysis records show this sample has been submitted and flagged as malicious since at least October 2015, confirming it is a well-established, long-known threat. The malware has been part of the theZoo public malware repository, widely used in academic and security research.



6. Indicators of Compromise (IoCs)

6.1 File Hashes

Sample	Hash Type	Value
bot.apk	MD5	f0a1475583278466b673ac902b664e42
bot.apk	SHA-1	aa9436771a1c98639d1deb7330c6aac524bb2aa4

bot.apk	SHA-256	2b29d93e58ab328a0c9418001d7748dc4c50b514c8074f4c00556b890df31644
ING.apk	MD5	f06af629d33f17938849f822930ae428
ING.apk	SHA-1	23f7a99cf90df9673d6c7ec31bed1e611b73003c
ING.apk	SHA-256	0106c6dce5f8e3615d3e9edc856230109ff06884a7c6ea4418eefab055270f1e
ING_.apk	MD5	e1b86054468d6ac1274188c0c579ccaf
ING_.apk	SHA-1	b6d2ec548be8836c5171fd0243813de1b6e01822
ING_.apk	SHA-256	38f6fccfc8a31306c0a03cad6908c148e8506fd70ce03165fd89e18113b68e02

6.2 Network IoCs

Type	Value
Domain	tmn.pt
IP Address	194.65.61.45
URL	http://tmn.pt/update/
URL	http://tmn.pt/android/sms/saveSMS.php
URL	http://tmn.pt/android/sms/sync.php
URL	http://tmn.pt/iBanking/sms/index.php
Phone Number	+70000000003 (bot.apk / ING.apk)
Phone Number	+447781481797 (ING_.apk — UK)

6.3 Host-Based IoCs

Type	Value
Package Name	com.BioTechnology.iClientsService4
Database File	iBankDB_23.db
Main Activity	com.soft360.iService.MainActivity
Malicious Service	com.soft360.iService.AService

Admin Receiver	com.soft360.web.MyAdmin
Boot Receiver	com.soft360.iService.AutoStart

Auth Key	637f-bsnj-70ak-bs2e
----------	---------------------

7. Risk Assessment

Category	Assessment
Overall Risk Level	HIGH
Confidentiality Impact	HIGH — SMS messages, contacts, IMEI, audio, and banking credentials are exfiltrated.
Integrity Impact	HIGH — Device administrator access allows remote wipe and password changes.
Availability Impact	MEDIUM — Persistent background service consumes resources; device admin can lock device.
Financial Impact	HIGH — Designed specifically to bypass banking 2FA and steal credentials.
Persistence	HIGH — Survives reboot; device admin makes removal difficult.
Stealth	HIGH — Impersonates trusted banking and security apps; no visible malicious UI.

8. Recommendations

- Never install Android applications from unofficial or unknown sources outside of trusted app stores
- Disable the 'Unknown Sources' setting on Android devices to prevent sideloading of APKs.
- Regularly review and audit applications installed on mobile devices, especially those requesting device administrator privileges
- Users should be educated to verify the authenticity of any application claiming to be a bank security tool or certificate generator before installation.
- Banks should implement app-based authenticators or hardware tokens instead of SMS-based OTPs, as SMS 2FA is vulnerable to this class of malware.

9. Conclusion

The static analysis of the three APK samples extracted from Android.Spy.49_iBanking_Feb2014.zip confirms that all samples are variants of the iBanking Android banking trojan and spyware. The malware is sophisticated, multi-functional, and deliberately designed to evade detection while harvesting sensitive financial and personal data from victims.

All three variants share the same core infrastructure (package name, C2 domain, permission set, and behavioural profile), confirming they are part of the same malware campaign. ING_.apk represents a more targeted variant with a distinct certificate, different C2 path, and UK-specific phone number suggesting separate distribution aimed at ING Bank customers in the United Kingdom.

The threat was independently confirmed as malicious by four external platforms (VirusTotal, MetaDefender, Hybrid Analysis, and Triage), with VirusTotal detecting it on 40–41 out of 68 engines and MetaDefender's sandbox assigning a 100/100 threat score. The malware has been publicly documented since at least 2013–2014 and remains a significant reference case in Android mobile banking malware research.